



State of Ohio Administrative Policy

Information Security and Privacy Awareness Training

No: IT-15

Information Technology

Effective:

April 29, 2025

Issued By:

Kathleen C. Madden, Director

I. Purpose

This policy provides information security and privacy awareness training requirements for **Organizational Users**. This policy is not intended for the general population that accesses electronic government services or applications. The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards in Technology (NIST) Special Publication (SP) 800-53 family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

This policy applies to all state Agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies).

III. Policy

Agencies shall conduct information security and privacy awareness training in accordance with the requirements outlined in this policy and shall ensure that all Organizational Users adhere to the policy.

- A. ***Basic Information Security and Privacy Awareness Training (AT-2)***: The Department of Administrative Services (DAS) Office of Information Security and Privacy (OISP) shall provide Basic Information Security and Privacy Awareness Training for Agencies to use to conduct this training.

1. DAS OISP shall work with Agencies to identify solutions for delivering Basic Information Security and Privacy Awareness Training statewide.
 2. The DAS OISP training shall be reviewed annually and updated as necessary to ensure it remains current, addressing the latest security and privacy threats and best practices.
 3. Agencies shall ensure that all Organizational Users complete the DAS OISP Basic Information Security and Privacy Awareness Training. Organizational Users shall complete the Basic Information Security and Privacy Awareness Training within two weeks of onboarding, annually thereafter; and when required by role or system changes.
 4. Agencies shall determine if it is necessary to augment DAS OISP's Basic Information Security and Privacy Awareness Training due to Agency specific requirements or any applicable laws, regulations, or industry codes that require some type of information security and privacy awareness training for the **Information Systems** to which personnel have authorized access. Examples of regulations or laws that require additional security training, include:
 - a) Accessing **Confidential Personal Information (CPI)** (Section 1347.15 of the Ohio Revised Code)
 - b) Family Educational Rights and Privacy Act (FERPA)
 - c) IRS Publication 1075
 - d) FBI Criminal Justice Information Services (CJIS) Security Policy
 - e) Health Insurance Portability and Accountability Act (HIPAA)
 - f) Payment Card Industry Data Security Standard (PCI-DSS)
 5. As appropriate, each Agency shall supplement the Basic Information Security and Privacy Awareness Training with tools that will help communicate local or programmatic information security issues, incidents, and procedures (e.g., "message of the day," posters, special events, e-mail notices).
- B. **Role-Based Security and Privacy Training (AT-3):** In addition to Basic Information Security and Privacy Awareness Training, Agencies shall provide Role-Based Security and Privacy Training that focuses on the unique responsibilities for protecting state assets that are inherent in particular job functions. Certain roles may require more targeted training, such as business managers, senior executives, information owners, application developers, systems administrators, database administrators, and desktop support.

1. Agencies shall identify the job functions that require additional role-based training and then determine the format, content, and frequency of the training. Listed below are a few examples of role-based training:
 - a) Business managers and senior executives:
 - (i) The safeguarding and use of **Personally Identifiable Information (PII)**.
 - (ii) Executive targeting threats such as social engineering and **Spear Phishing**.
 - (iii) Identification of suspicious messages and the importance of not opening suspicious e-mails or attachments.
 - (iv) Examples of prominent cyberattacks.
 - b) Application developers, system administrators and database administrators:
 - (i) How to write secure code and use appropriate validation tools.
 - (ii) Proper security testing methods.
 - (iii) How to handle **Confidential Data**.
 - c) Desktop and **Infrastructure** Support:
 - (i) **System Hardening** techniques.
 - (ii) How to recognize attacks.
 - (iii) Handling systems infected with **Malware**.
 2. DAS OISP shall help inform and support these efforts through a variety of channels, such as security communications (e.g., current threats, countermeasures, or training opportunities), best practices research and resources, security briefings or conferences.
- C. **Information Security and Privacy Awareness and Training Management:** Agencies shall ensure that all Organizational Users meet the training requirements of this policy by identifying, monitoring and managing the overall IT security education effort. Agencies shall identify all individuals requiring Basic Information Security and Privacy Awareness Training and role-based training.
- D. **Security Training Records (AT-4):** Agencies shall maintain individual security training records in accordance with Agency record retention requirements, to ensure that Basic Information Security and Privacy Awareness Training and role-based training requirements are being fulfilled.

- E. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.
1. The form is located within the IT Enterprise Services Portal under the "Services & Products" category.
 2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Basic Information Security and Privacy Awareness Training. The purpose of this type of training is for the participant to gain a basic understanding of the need for information security and privacy and the actions that he/she can take to maintain security and privacy and respond to suspected incidents. This training also increases awareness regarding the importance of operations security.
- C. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- D. Confidential Personal Information (CPI). Personal information that falls within the scope of Section 1347.15 of the Ohio Revised Code and that an Agency is prohibited from releasing under Ohio's public records law.
- E. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- F. Information System. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.³

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ *Ibid.*

- G. Infrastructure. The collective resources, hardware, software, and network, needed to support the delivery of services and the overall IT environment.
- H. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁴
- I. Malware. A program that is inserted into a system, usually covertly, with the intent of compromising the **Confidentiality, Integrity, or Availability** of the victim's data, applications, or operating system or of otherwise annoying or disrupting the victim.⁵
- J. Organizational User. An Organizational User is anyone who is an employee of the state, or is otherwise authorized to work on behalf of the State, and who has a need to access State of Ohio IT systems and has secured Agency authorization for such access. The Organizational User identifier will help to distinguish the individual during the authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User identifier category may also include university and federal government resources.
- K. Personally Identifiable Information (PII). "Personally identifiable information" is information that can be used directly or in combination with other information to identify a particular individual. It includes:
 - 1. a name, identifying number, symbol, or other identifier assigned to a person,
 - 2. any information that describes anything about a person,
 - 3. any information that indicates actions done by or to a person,
 - 4. any information that indicates that a person possesses certain personal characteristics.⁶
- L. Role-Based Security and Privacy Training. Role-based training strives to produce relevant and needed security and privacy knowledge and skills within the workforce. Role-Based Security and Privacy Training supports competency development and helps personnel understand and learn how to better perform their specific security or privacy role, which ultimately achieves more secure and protected information and systems.

⁴ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ Souppaya, Murugiah, Karen Scarfone. "NIST Special Publication 800-83, Revision 1, Guide to Malware Incident Prevention and Handling for Desktops and Laptops" U.S. Department of Commerce National Institute of Standards and Technology, July 2013, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-83r1.pdf>>.

⁶ Based on Ohio Revised Code Section 1347.01 (E).

- M. Spear Phishing. Phishing is the act of tricking individuals into disclosing confidential personal information through deceptive computer-based means.⁷ “Spear” phishing is a highly targeted attack aimed at a specific individual(s).
- N. System Hardening. The process of enhancing the default or basic security layers associated with an application and/or network. The primary purpose of System Hardening is to increase the level of system security to dissuade and defeat intrusion or security breach attempts. Hardening concepts may include, but are not limited to, the application of system or application patches, removal of all unnecessary system features or services, shutting down of all unnecessary ports, incident logging, installation of a demilitarized zone (DMZ), packet filtering, cryptography, strong authorization, data encryption, and system/network monitoring and/or auditing.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://csrc.nist.gov/publications/sp
Ohio IT Standard ITS-SEC-02, “Enterprise Security Controls Framework”	https://das.ohio.gov/technology-and-strategy/policies
Center for Internet Security (CIS) Controls	https://www.cisecurity.org/controls/
Multi-State Information Sharing & Analysis Center (MS-ISAC) Resources	https://www.cisecurity.org/ms-isac/

⁷ Souppaya, Murugiah, Karen Scarfone. “NIST Special Publication 800-83, Revision 1, Guide to Malware Incident Prevention and Handling for Desktops and Laptops” U.S. Department of Commerce National Institute of Standards and Technology, July 2013, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-83r1.pdf>>.

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 19th Floor
Columbus, Ohio 43215

1-614-644-9391 | state.isp@das.ohio.gov

State of Ohio Administrative Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
07/01/2015	Original Policy.
04/10/2018	References to NIST SP 800-53 control families were added to the requirements, where appropriate. A definition of Sensitive Data was also added. The exception request section was removed and procedural guidance was added in its place. The implementation section was modified due to the time elapsed since the publication of the policy on 7/21/15.
11/21/2018	Updated the exception request language to align with the current procedure.
07/22/2021	Updated the policy template to reflect the DAS director change.
02/10/2022	Conducted maintenance review and made minor updates to align with current training approach, terminology, references, and policy template.
09/05/2023	Updated the policy template. Added revision history review frequency statement.

Date	Description of Change
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data.